

Red Hat Hardened Images 와 Anchore 로 CVE 피로 줄이기

요약

검색

2026 년 5 월 13 일 3 분 읽기 [Hardened images](#), [보안](#)

컨테이너로 소프트웨어를 배포한다면 취약점의 쳇바퀴를 잘 알 것이다. 스캐너는 수많은 CVE 를 쏟아내고, 백로그는 불어나며, 팀은 마치 그것이 회사의 본업인 것처럼(고객과 이해관계자를 위한 서비스가 아니라) 패치 속도를 쫓는다. 문제를 더 복잡하게 만드는 것은, 그 긴 스캔 결과가 정작 가장 중요한 질문에 답하지 못한다는 점이다. 즉, 이 발견 항목 중 지금 고쳤을 때 우리의 리스크를 실질적으로 바꿔 놓는 것은 무엇인가?

그렇게 늘어난 부담과 압박의 상당 부분은 노이즈다. 결과에는 실제로 실행되지 않는 패키지, 도달할 수 없는 경로, 사실상 다른 곳에서 소유하고 유지 관리하는 구성 요소와 관련된 항목이 포함된다. 모든 항목을 프로덕션 장애처럼 다루는 것은 보안 수준을 높여주지 않는다. 오히려 정말로 중요한 문제에 대한 대응을 느리게 만든다.

많은 조직에서 "모든 것을 패치한다"에서 최소주의적이고 리스크 기반의 태세로 전환이 진행되고 있다.

- 최소한의 컨테이너 이미지, 즉 의도적으로 작게 만든 하드닝된 기반으로 노이즈를 근원에서 줄인다.
- SBOM(소프트웨어 구성 명세서)에 기반한 지속적인 가시성과 정책을 더해, 팀이 무엇을 배포하는지 증명하고 약속한 바를 강제하며 스스로 통제할 수 있는 항목에 대응을 집중하도록 한다.

먼저 노이즈를 근원에서 없애는 일부터 시작하자. Red Hat Hardened Images 는 범용적인 "없는 것 없이 다 넣은" 빌드가 아니라, 프로덕션에 필요한 것만으로 구성된, 설계 자체가 최소화된 컨테이너 이미지를 제공하려는 의도적인 접근 방식을 반영한다. 패키지와 바이너리가 적다는 것은 결함이 숨을 곳이 적고, 전이 의존성이 적으며, 스캐너가 찾아내는 항목도 적다는 뜻이다.

그다음은 SBOM 이다. 컴플라이언스 팀은 추적 가능성 때문에 SBOM 에 관심을 두지만, 플랫폼 및 애플리케이션 엔지니어도 관심을 가져야 한다. SBOM 이 곧 내가 방어할 각오가 되어 있는 대상의 지도이기 때문이다. 더 작고 의도적으로 구성된 명세는 공격 표면 축소, 트리아지 노이즈 감소, 그리고 실제 문제가

발생했을 때 더 빠른 대응과 연결되는 경향이 있다. 무엇이 영향을 받는지, 해당 구성 요소가 어떤 이미지에 포함되어 있는지 정확히 알 수 있기 때문이다.

이미지를 보호하고 컴플라이언스를 유지하기

이 과제를 해결하기 위해 Red Hat 은 SBOM 기반 공급망 보안 분야의 선도 기업인 [Anchore](#) 와 협력했다. Anchore 는 컴플라이언스 운영 엔진으로 널리 인정받고 있으며, 기업들은 이를 통해 SBOM 을 생성·관리하고 취약점 분석을 자동화하며 수명 주기 전반에 걸쳐 정책 기반 컴플라이언스를 강제한다. Anchore 의 목표는 사용자가 공급망 리스크를 통제하고 기본적으로 컴플라이언스를 유지할 수 있게 하는 것이다.

Red Hat 은 Red Hat Hardened Image 카탈로그를 만드는 과정에서 새로운 취약점을 식별하는 데 그치지 않고, 고객 환경에서 이미지가 (종종 매일) 필수적으로 갱신되는 과정의 핵심 요소가 되기 위해 Anchore 와 협력하고 있다. 새로운 CVE 가 공개되거나 업스트림에 유입되면, Anchore 는 개발 또는 프로덕션에서 사용 중인 이미지를 스캔해 영향 여부를 확인할 수 있다. 문제가 Red Hat Hardened Image 에 있다면, Red Hat 리포지토리에서 최신 이미지를 가져오도록 알리를 보낼 수 있다. 취약점이 개발자가 이미지에 추가한 콘텐츠에 있다면, 개발자의 톨체인으로 알리를 보낼 수 있다.

중요한 점은 관련된 팀이나 도구만 해당 알리를 받는다는 것이다. 또한 Anchore 의 정책 엔진은 Red Hat Hardened Images 사용을 강제해 업스트림이나 다른 서드파티 이미지가 사용되지 않도록 할 수 있다. 프로세스 전체 수명 주기에 걸쳐 Anchore 는 모든 이미지의 SBOM 을 수집·보관해 컴플라이언스 요구 사항을 충족하도록 한다.

통합 워크플로

처음부터 끝까지 동작 방식은 다음과 같다.

1 단계: 빌드

Red Hat Hardened Image 에서 시작해 런타임 이미지를 가볍게 유지하고 공격 표면을 최소화하는 데 집중한다. 모든 이미지는 SLSA3 빌드 표준에 따라 생성된다.

2 단계: 분석

CI/CD 와 레지스트리 승격 경로에서 빌드된 아티팩트에 대해 Anchore 분석을 지속적으로 수행한다. 실무적으로는 SBOM 생성 및 가져오기, 취약점 매칭, 정교한 컴플라이언스 정책 검사를 의미한다.

3 단계: 필터링

SBOM 비교와 워크플로 규율을 활용해 무엇이 변경되었고 무엇이 도달 가능하며 유의미한지에 집중한다. 최소화된 베이스 이미지는 의도한 대로 무관한 발견 항목의 모수를 줄여준다. 목표는 사람의 주의력 한계를 존중하는 트리아지다.

4 단계: 정책 적용(통과하지 못하면 배포되지 않는다)

여기서 Anchore의 정책 엔진이 역할을 한다. 레지스트리로 승격되거나 배포되기 전에, 이미지는 NIST 800-53, 800-190, FedRAMP 같은 일반적인 표준을 기준으로 컴플라이언스 위반 여부를 평가받을 수 있다. 중요한 영역은 담당 팀에 플래그로 표시된다. 이미지가 배포 준비를 마치면 SBOM은 컴플라이언스 감사를 위해 보관된다.

직접 사용해 보기

스캔만으로는 비대해진 기반을 고칠 수 없다. Red Hat Hardened Images는 비용이 가장 적게 드는 지점, 즉 발견 항목이 생기기 전에 CVE 피로 문제를 공략한다. Anchore는 SBOM 기반 가시성, 지속적인 스캔, 정책 자동화로 그 고리를 완성한다. 여기에는 NIST와 FedRAMP 같은 프레임워크의 요구 사항을 충족하고 CRA와 같은 규제 압력에 대응하도록 돕는 컴플라이언스 자동화 및 리포팅도 포함된다.

지금 무료로 직접 사용해 보세요. [Red Hat Hardened Images](#).